

Hackhub 游戏手册

指南与参考。 · 89 篇文章



账户

1 篇文章



挖掘

2 篇文章



Metasploit

6 篇文章



脚本编写

14 篇文章



怀疑

4 篇文章



终端命令

32 篇文章



Python 模块

9 篇文章



Online World

21 篇文章

内容完整提取自 Hackhub 游戏内置 Handbook（简体中文，与游戏内文本一致，部分文章游戏内本身未翻译）。仅供个人游戏参考使用。

账户

没有选择的内容。

1 篇文章 · 返回目录: [内容](#)

挖掘

寻找用户密码

劫持防火墙

挖掘

没有选择的内容。

2 篇文章 · 返回目录: [内容](#)

METASPLOIT

- 引导
- 如何黑客
- 例子黑客
- Rootgrab
- Payloads
- Reverse TCP

Metasploit

没有选择的内容。

6 篇文章 · 返回目录: [内容](#)

脚本编写

创建你自己的程序

将代码转换为命令

模块与导入

系统

外壳

包裹

调试

线索

文件系统

Networking

Networking.Wifi

Crypto

HackDB

NTLM

脚本编写

没有选择的内容。

14 篇文章 · 返回目录: [内容](#)

怀疑

什么是怀疑？

我的怀疑水平如何增加？

如何减少怀疑水平？

高怀疑水平

怀疑

没有选择的内容。

4 篇文章 · 返回目录: [内容](#)

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

终端命令

没有选择的内容。

32 篇文章 · 返回目录: [内容](#)

PYTHON 模块

- Evil-Rm
- Fern
- JWT Decoder
- Kimai
- Net Tree
- Pret
- pyUserEnum
- Sqlmap
- WigleNet

Python 模块

没有选择的内容。

9 篇文章 · 返回目录: [内容](#)

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

Online World

没有选择的内容。

21 篇文章 · 返回目录: [内容](#)

如何恢复您的账户？如果您已经创建了一个账户，系统会自动记录相关日志。要查看这些日志，请查看 `/logs/accounts.log` 文件。

```
/logs/accounts.log
```

如何在远程连接中查找用户密码？当你访问一个系统时，你可能需要用户的密码。密码在操作系统中以加密形式存储。这些密码存储在这个文件中：

```
/etc/passwd
```

如果你愿意，你可以完全解密这个文件，或者逐个解密其中的哈希。要做到这一点，需要一个工具。

```
apt-get install john
```

然后

```
john <hash>
```

识别防火墙

在我们开始凭证提取流程之前，必须确定防火墙的 IP 地址。假设目标防火墙 IP 是 **44.55.66.77**。

所需工具

要执行此操作，你需要以下内容：

- **Wireshark** — 用于监控网络数据包
- **Kimai 攻击脚本** — 可从 *hackdb.net* 下载
- **JWT 解码器** — 也可在 *hackdb.net* 获取这三个工具配合使用，用于捕获并解码认证 token。

准备 Wireshark

打开 **Wireshark** 并将其配置为最大可视性。在 **Source** 和 **Destination** 过滤器中，输入：

```
*
```

这允许 Wireshark 不受限制地捕获所有传入与传出数据。设置过滤器后，按下 **Start** 开始实时抓包。你现在应该能在数据包列表中看到持续的流量。

使用 Kimai 生成流量

接下来，我们必须对目标防火墙生成活动，以迫使其产生会话相关数据。在你的终端中，启动以防火墙为目标的 Kimai 脚本：

```
python3 ./kimai.py [ip address]
```

示例：

```
python3 ./kimai.py 44.55.66.77
```

每次执行 可能会或不会捕获到 cookie。因此，你必须反复运行 Kimai 脚本，直到在 Wireshark 中出现可用的 token。当 Kimai 运行时，Wireshark 应显示连续的数据包流。

在 Wireshark 中查找 Cookie

监控 Wireshark 中的 **Info** 列。当出现 cookie 或 token 时，通常会显示为一个较短的编码字符串或会话引用。继续运行 Kimai 并监控数据包，直到出现类似 cookie 的条目。一旦出现，即表示数据已成功捕获。点击该数据包以查看其详细内容，然后复制 token。

解码 Token

现在你已获得捕获的 token，使用 JWT Decoder 工具。按如下方式运行解码脚本：

```
python3 ./jwt_decoder.py [token]
```

示例：

```
python3 ./jwt_decoder.py eyJhbGciOiJIUzI1NiIsInR5cCI6...
```

解码器将处理 token 并显示其内容。在解码后的字段中，你会找到防火墙的登录凭证。

结论

在此阶段：

1. 已识别防火墙 IP
2. 已配置 Wireshark 以捕获所有流量
3. Kimai 生成强制流量以获取 token
4. 在 Wireshark 抓包中找到了 cookie
5. 使用 JWT Decoder 解码了 token
6. 已成功提取防火墙登录凭证

Metasploit 介绍

Metasploit 是一个渗透测试工具，用于检测和测试安全漏洞。它被合法黑客和网络安全专业人员用来识别系统中的弱点并改善防御。然而，它也可以被恶意行为者用于攻击，因此应该小心使用并在法律范围内使用。安装

```
apt-get install metasploit
```

用法

```
msfconsole
```

如何使用 Metasploit 进行攻击？

Metasploit 被分为多个漏洞利用模块。尽管每个漏洞利用的使用方式不同，但其工作方式大致相同。我们不能单独使用 Metasploit，我们需要配合一些工具一起使用。例如，我们需要使用 **nmap** 来了解我们想要渗透的系统上正在运行哪些服务，哪些端口是活跃的。根据我们找到的结果，如果某个端口是开放的，并且我们知道运行的版本，我们通常可以渗透该系统。让我们开始吧。

扫描目标

例如，假设我们的目标 IP 地址是 **11.22.33.44**。我们应该先扫描目标，再开始 hack。

```
nmap 11.22.33.44 -sV
```

我们得到的结果：

PORT STATE SERVICE VERSION DESTINATION	----	----	----	----	----	21 OPEN ftp vsftpd 2.3.5
192.168.1.2	22 CLOSE ssh openssh 1.8.6	192.168.1.2	80 CLOSE http nginx 7.23.4	192.168.1.2		

从这里我们理解到 21 端口是打开的，并且后台运行的服务是 **"vsftpd 版本 2.3.5"**。现在我们可以开始使用 metasploit。

```
msfconsole
```

搜索 Exploit

我们知道目标有一个打开的端口和一个正在运行的服务。接下来，我们需要找到一个与之匹配的 exploit。

```
search [running service name]
```

"vsftpd 2.3.5" 正在目标端口上运行。我们需要为 vsftpd 寻找合适的 exploit。

```
search vsftpd
```

# Name Disclosure Date Rank Description	----	----	----	----	----	0 auxiliary/dos/ftp/vsftpd 2020-02-03 normal VSFTPD Denial of Service
---	------	------	------	------	------	---

我们找到了一个可用的 exploit。我们需要测试它。为了使用我们在搜索后找到的 exploit，我们需要使用 **"use"** 命令。

```
use [exploit name or index]
```

在这个示例中

```
use 0
```

或者

```
use auxiliary/dos/ftp/vsftpd
```

进行配置

我们找到了 `exploit`，并使用 `"use"` 命令启用了它。现在我们需要配置正在使用的模块。

```
show options
```

使用此命令后，我们展示了模块的当前设置。

```
| Name | Current Settings | Required | Description | | ---- | ---- | ---- | ---- | | RHOST | | yes | The target host | | RPORT | 21 | yes | The target host | | Version | 1.0.0 | yes | The target host |
```

我们必须填写 `Required = "yes"` 的字段我们使用 `"set"` 命令填写这些字段。

```
set RHOST 11.22.33.44
```

```
set Version 2.3.5
```

注意：某些字段可能会默认填充，你应该用关于你目标的信息替换它们。当你填写完所有必填字段后，就可以开始攻击。

发起攻击

现在我们已经完成所有设置，可以开始攻击。通常该命令是 `"exploit"`。不过，有时也可能是其他命令。你可以通过输入 `"help"` 来了解。

```
exploit
```

如果一切都正确，你将已经渗透系统，`metasploit` 会给你一个 `meterpreter` 会话。

METASPLOIT

- 引导
- 如何黑客
- 例子黑客
- Rootgrab
- Payloads
- Reverse TCP

Rootgrab这个 metasploit 工具从 passwd 文件获取 root 密码哈希。用法（在 meterpreter 中）

```
rootgrab /path/to/passwd
```

示例

```
rootgrab /etc/passwd
```

提示通常 passwd 文件位于 /etc 目录下。

METASPLOIT

- 引导
- 如何黑客
- 例子黑客
- Rootgrab
- Payloads**
- Reverse TCP

Metasploit 载荷您可以向某些 Metasploit 利用程序添加载荷。这些载荷是将在目标系统上运行的代码脚本。最著名的是 `bearos/meterpreter/reverse_tcp`

用法 `set payload <载荷名称>`

示例 `set payload bearos/meterpreter/reverse_tcp`

METASPLOIT

引导

如何黑客

例子黑客

Rootgrab

Payloads

Reverse TCP

Metasploit 反向 TCP

在某些情况下，通往目标系统的大多数路径都被关闭，我们无法通过攻击访问它们。然而，目标可以为我们打开一条进入的路径，称为反向 TCP。欺骗某人的最常见方式是通过文件。看似无害的 Word 文档可能携带看起来并不隐藏的恶意软件。我们在这里将使用的利用工具是 `exploit/multi/fileformat/office_word_macro`

用法

- `search office_word_macro`
- `use exploit/multi/fileformat/office_word_macro`
- `set payload bearos/meterpreter/reverse_tcp`
- `show options`
- `set LHOST 192.168.1.2`
- `set LPORT 4444`
- `run`（创建恶意 Word 文档）
- `handler`（启动监听器）
- 将文件发送到目标当连接到来时
- 使用 `Ctrl+C` 退出处理程序。
- `show sessions`
- `session <session index>`

重要
在这里，我们将有效载荷的 LPORT（即，本地端口）设置为 4444。您可以将其设置为您喜欢的任何端口。但是，请记住，您必须从您连接的网络的调制解调器界面打开此端口。否则，有效载荷将无法正常工作。

我要怎么创建自己的程序？

你可以通过写自己的程序，把黑客操作或者其他事情自动化。

这件事用 **Code++** 应用来做。

Hackhub 的脚本支持 **TypeScript** 语言。

你可以直接用标准的 TypeScript 语法。除此之外，Hackhub 还定义了一批用来操作游戏的函数和库。

Code++ 编辑器功能

- **多标签编辑** – 同时打开并处理多个文件。拖动标签可以调整顺序。
- **主题** – 在设置里从 20 种配色主题中挑选（Dracula、Tokyo Night、Catppuccin 等）。
- **字体** – 在设置里选择你喜欢的字体和字号。
- **IntelliSense** – 对所有内置 API 提供完整的自动补全和类型检查。
- **导入支持** – 用 `import` / `export` 把代码拆分到多个文件（见“模块与导入”）。

代码我写好了，但要怎么运行？

写完程序之后，你需要 "node.js" 包才能运行它。

```
apt-get install node
```

然后运行你保存好的 typescript 文件。

```
node /path/to/yourprogram.ts
```

你也可以在 Code++ 里按 **Play** 按钮，直接运行当前文件。

将代码转换为命令在编写程序后，我们使用 "node" 命令运行它。那么我们如何将这个程序变成一个终端命令呢？如果你将创建的代码文件放入 "lib" 文件夹中，那么该文件将作为一个特殊命令运行。示例：

```
/lib/myprogram.ts
```

在终端中：

```
myprogram
```

另一个示例：

```
/lib/custom-tool.ts
```

```
custom-tool
```

模块与导入

你可以把代码拆分到多个文件里，并用标准的 TypeScript 语法在它们之间导入和导出。

导出

用 `export` 把函数、类或变量开放给其他脚本使用。

```
// utils.ts
export function greet(name: string) {
  println("Hello, " + name + "!");
}

export const VERSION = "1.0";

export async function doWork() {
  println("Working...");
  await sleep(1000);
  println("Done.");
}
```

导入

用 `import` 引入另一个文件导出的内容。路径相对于当前文件。

```
// main.ts
import { greet, VERSION, doWork } from "./utils";

greet("World");
println("Version: " + VERSION);
await doWork();
```

它是怎么工作的

- 文件是相对于导入方所在目录解析的（同级文件）。
- `.ts` 扩展名可以省略 – `"./utils"` 和 `"./utils.ts"` 都能用。
- 所有内置函数（`println`、`sleep`、`prompt`、`Shell`、`Networking` 等）在被导入的模块里同样可用。
- 导入是递归解析的 – 被导入的文件还可以再导入别的文件。

多文件项目示例

```
// scanner.ts
export async function scanTarget(ip: string) {
    const subnet = await Networking.GetSubnet(ip);
    if (!subnet) throw "No subnet found!";
    const ports = await subnet.GetPorts();
    return ports;
}
```

```
// main.ts
import { scanTarget } from "./scanner";

const ip = await prompt("Target IP: ");
const ports = await scanTarget(ip);
println("Open ports: " + ports.join(", "));
```

类型支持

Code++ 编辑器为导入提供完整的 IntelliSense。当你输入 `import { } from "./file"` 时，编辑器会自动补全那个文件导出的符号。

Lib – System

供你的脚本使用的基础 I/O 函数。

打印输出

```
println("Hello World!");  
println(42);
```

彩色输出

```
println({ text: "Success!", color: "green" });  
println({ text: "Error!", color: "red", backgroundColor: "#333" });
```

行内彩色文本

```
println([  
  { text: "Status: ", color: "white" },  
  { text: "OK", color: "green" }  
]);
```

打印表格

用格式化的 ASCII 表格显示数据。

```
printTable([  
  { Name: "SSH", Port: 22, Status: "open" },  
  { Name: "HTTP", Port: 80, Status: "closed" }  
]);
```

换行

```
newLine();
```

用户输入

```
const ip = await prompt("IP Address: ");  
println(`You entered: ${ip}`);
```

密码输入（隐藏）

```
const pass = await prompt({ label: "Password: ", password: true });
```

Lib – Shell

从你的脚本里管理终端。

终端锁定

在耗时较长的操作期间锁定终端输入。

```
await Shell.lock();    // 锁定输入
await Shell.unlock();  // 解锁输入
await Shell.isLocked(); // -> boolean
```

清空终端

```
await Shell.clear();
```

参数

获取传给脚本的命令行参数。

示例: `myprogram -ip 192.168.1.1 -port 21`

```
const args = Shell.GetArgs();
// -> ["-ip", "192.168.1.1", "-port", "21"]
```

执行命令

从你的脚本里运行终端命令。

```
await Shell.Process.exec("nmap 192.168.1.1 -sV");
```

带工作目录选项:

```
// 在指定的子目录中运行
await Shell.Process.exec("cat passwords.txt", {
  cwd: "documents"
});
```

```
// 用绝对路径运行
await Shell.Process.exec("ls", {
  cwd: "/home/user/desktop",
  absolute: true
});
```

库 – 包检查一个包是否已安装

```
checkLib( packageName: string ) -> Promise<boolean>
```

示例

```
await checkLib( "lynx" )
```

如果包已安装则返回 true，未安装则返回 false。

安装包

```
installLib( packageName: string ) -> Promise<boolean>
```

示例

```
const isInstalled = await installLib( "lynx" );  
println( isInstalled ); // 返回 true 或 false。
```

脚本编写

创建你自己的程序

将代码转换为命令

模块与导入

系统

外壳

包裹

调试

线索

文件系统

Networking

Networking.Wifi

Crypto

HackDB

NTLM

Lib – 调试您可以使用游戏开发者控制台记录您的输出。使用 "F1" 键来做到这一点。

```
Debug.Log("Hello World!");
```

```
Debug.Error("这是错误! ");
```

Lib – Thread

用于线程操作。

To wait

```
sleep(timeout: number (ms)) -> Promise<void>
```

```
println("Loading...");  
await sleep(2500); // 等待 2.5 秒  
println("Done.");
```

Lib – File System

管理这台计算机上的文件和目录。

大多数方法都接受一个可选的 `options` 参数：

- `absolute` – 从根目录而不是当前目录解析路径
- `recursive` – 自动创建中间目录（Mkdir、WriteFile）

当前工作目录

```
const info = await FileSystem.cwd();
println(info.name);           // "desktop"
println(info.currentPath);    // "desktop"
println(info.absolutePath);   // "/home/user/desktop"
```

切换目录

```
await FileSystem.SetPath("documents");
await FileSystem.SetPath("/home/user", { absolute: true });
```

列出文件

```
const files = await FileSystem.ReadDir(".");
if (!files) throw "Cannot access directory!";
for (const file of files) {
    println(`${file.name} - ${file.isFolder ? "folder" : file.extension}`);
}
```

读取文件

```
const content = await FileSystem.ReadFile("notes.txt");  
println(content);
```

写入文件

创建一个新文件，或者覆盖已有的文件。

```
await FileSystem.WriteFile("output.txt", "Hello World!");  
  
// 自动创建上级目录  
await FileSystem.WriteFile("deep/path/file.txt", data, {  
    recursive: true  
});
```

创建目录

```
await FileSystem.Mkdir("my-folder");  
await FileSystem.Mkdir("path/to/folder", { recursive: true });
```

删除文件或文件夹

```
await FileSystem.Remove("old-file.txt");
```

Lib – Networking

网络操作与子网分析。

校验 IP 地址

```
await Networking.IsIp("192.168.1.1"); // true
await Networking.IsIp("abc");          // false
```

获取子网

```
const subnet = await Networking.GetSubnet("11.22.33.44");
if (!subnet) throw "Subnet not found!";
println(subnet.ip);    // "11.22.33.44"
println(subnet.lanIp); // "192.168.1.2"
```

子网方法

```
const subnet = await Networking.GetSubnet(ip);

// 获取这个子网的路由器
const router = await subnet.GetRouter();

// 列出开放的端口号
const ports = await subnet.GetPorts(); // -> number[]

// 检查某个特定端口是否开放
const isOpen = await subnet.PingPort(22); // -> boolean

// 获取详细的端口信息
const portData = await subnet.GetPortData(22);
```

```
if (portData) {  
    println(portData.service); // "ssh"  
    println(portData.version); // "OpenSSH 8.2"  
    println(portData.external); // 22  
    println(portData.internal); // 22  
    println(portData.target); // "192.168.1.2"  
}
```

Lib – Networking.Wifi

无线网络扫描与攻击工具（类似 Bettercap）。

列出接口

```
const interfaces = await Networking.Wifi.GetInterfaces();
for (const iface of interfaces) {
  println(`${iface.name} - monitor: ${iface.monitor}`);
}
// wlan0 - monitor: true
// wlan1 - monitor: false
```

扫描网络

需要一个支持监听模式的接口（例如 `wlan0`）。

```
const networks = await Networking.Wifi.Scan("wlan0");
for (const ap of networks) {
  println(`${ap.ssid} | ${ap.bssid} | Ch:${ap.channel} | Signal:${ap.signal}`);
}
```

取消认证攻击

发送 deauth 帧，把客户端从接入点上踢下来。

```
await Networking.Wifi.Deauth("wlan0", targetBssid);

// 自定义数据包数量
await Networking.Wifi.Deauth("wlan0", targetBssid, { packets: 10 });
```

捕获 WPA 握手包

捕获 WPA 握手包，并在当前目录下保存为一个 `.pcap` 文件。

```
const pcapFile = await Networking.Wifi.CaptureHandshake("wlan0", bssid);
println(`Saved: ${pcapFile}`); // "networkname.pcap"
```

完整示例 – Wi-Fi 破解器

```
const ifaces = await Networking.Wifi.GetInterfaces();
const mon = ifaces.find(i => i.monitor);

const networks = await Networking.Wifi.Scan(mon.name);
const target = networks[0];

await Networking.Wifi.Deauth(mon.name, target.bssid);
const pcap = await Networking.Wifi.CaptureHandshake(mon.name, target.bssid);

const password = await Crypto.Hashcat.Decrypt(pcap);
println(`Password: ${password}`);

await Networking.Wifi.Connect(target.bssid, password);
```

连接

通过 SSID 或 BSSID 连接到接入点。当找不到目标、多个网络使用同一 SSID，或密码被拒绝时会抛出错误。

```
await Networking.Wifi.Connect("HOME_5Ghz", "letmein123");

// 不传密码时会在终端中提示输入（输入会被隐藏）
await Networking.Wifi.Connect(target.bssid);
```

当前连接

```
const ap = await Networking.Wifi.GetCurrent();
println(ap ? `Connected: ${ap.ssid}` : "Offline");
```

断开连接

没有可断开的连接时返回 `false`。

```
await Networking.Wifi.Disconnect();
```

Lib – Crypto

加密工具与密码破解。

Hashcat – 破解 Wi-Fi 密码

解密捕获到的 `.pcap` 文件，还原出 Wi-Fi 密码。

```
const password = await Crypto.Hashcat.Decrypt("capture.pcap");
println(`Cracked: ${password}`);
```

带路径选项：

```
// 从指定目录解析
await Crypto.Hashcat.Decrypt("capture.pcap", { cwd: "downloads" });

// 从根目录解析
await Crypto.Hashcat.Decrypt("capture.pcap", { absolute: true });
```

哈希工具

```
// 生成 MD5 哈希
const hash = Crypto.Hash.md5("hello world");

// 加密一个密码（会保存映射，方便之后解密）
const encrypted = await Crypto.Hash.encrypt("mypassword");

// 解密之前加密过的哈希
```

```
const original = await Crypto.Hash.decrypt(encrypted);  
println(original); // "mypassword"
```

Lib – HackDB

用代码访问漏洞利用数据库。

列出所有漏洞利用

```
const exploits = await HackDB.ListExploits();
for (const exploit of exploits) {
  println(`${exploit.title} - ${exploit.service} ${exploit.version}`);
}
```

搜索漏洞利用

```
const results = await HackDB.SearchExploits("ftp");
printTable(results.map(e => ({
  Title: e.title,
  Service: e.service,
  Version: e.version
})));
```

下载漏洞利用

```
// 下载到 ~/downloads (默认位置)
await HackDB.DownloadExploit("sqlmap");

// 下载到指定目录
await HackDB.DownloadExploit("wordlist", "tools");

// 用绝对路径下载
await HackDB.DownloadExploit("kimai", "/home/user/desktop", {
```

```
    absolute: true  
  });
```

Lib – NTLM

NTLM 认证攻击库。

检查 NTLM 服务

检查目标是否启用了 NTLM 认证。

```
const hasNtlm = await NTLM.Check("11.22.33.44");
if (!hasNtlm) throw "No NTLM service found.";
```

连接并导出哈希

```
const connection = await NTLM.Connect("11.22.33.44");
const instance = await connection.GetInstance("2"); // NTLM 版本
await instance.Dump("admin"); // 导出这个用户的 NTLM 哈希
```

完整示例

```
const ip = "11.22.33.44";

if (await NTLM.Check(ip)) {
  println("NTLM service found, connecting...");
  const conn = await NTLM.Connect(ip);
  const ntlm = await conn.GetInstance("2");
  await ntlm.Dump("admin");
  println("NTLM hash dumped successfully.");
}
```

什么是怀疑等级？

怀疑等级，顾名思义，表示您在游戏中的怀疑程度。在黑客或引诱某人时要小心！

当您的怀疑等级达到50%以上时，有人可能会黑您的系统。如果怀疑等级达到100%，您将被抓住并输掉游戏。

怀疑

什么是怀疑？

我的怀疑水平如何增加？

如何减少怀疑水平？

高怀疑水平

我的怀疑程度如何增加？在游戏中，当你在黑客阶段或发送网络钓鱼邮件时进行不完整或错误的操作，通常会增加你的怀疑程度。

黑客

- 当你访问系统时，你需要找到访问日志。
- 然后，你应该删除表明你已获得 shell 的日志，不要触碰其他日志，否则缺失的日志会被系统管理员发现。

网络钓鱼邮件

- 发送网络钓鱼邮件时，确保你输入数据正确，否则你会引起怀疑！

怀疑

什么是怀疑？

我的怀疑水平如何增加？

如何减少怀疑水平？

高怀疑水平

如何降低 Suspicion?

- 你可以更改已连接的 Wi-Fi 网络，这将更改 IP 和 DNS 地址，从而降低你的 suspicion level.

怀疑

什么是怀疑？

我的怀疑水平如何增加？

如何减少怀疑水平？

高怀疑水平

当怀疑程度高时会发生什么？

- 如果你的怀疑程度为 50% 或更高，随时都有可能被黑客攻击。这些攻击包括迷你游戏，如果你在这些迷你游戏中成功，你将避免被攻击，如果失败，你将受到惩罚，比如失去你的钱。
- 如果怀疑程度达到 100%，你将被联邦当局扣押并失去你所有的钱。

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令：apt-get install

安装终端命令包。用法

```
apt-get install [package name]
```


命令: bettercap

Bettercap 是一个强大、模块化且易于扩展的框架，专为网络攻击和监控而设计。安装

```
apt-get install bettercap
```

启动

```
bettercap
```

开始探测

```
net.probe on
```

显示网络接口列表

```
net.show
```

将 wifi 侦测设置为启用监控模式的接口

```
wifi.recon [interface]
```

然后显示 wifi 列表

```
wifi.show
```

设置目标 wifi

```
set wifi.ap [BSSID]
```

向目标发送去认证包

```
wifi.deauth
```

退出 bettercap

```
exit
```

安装 hashcat 以解密哈希

```
apt-get install hashcat
```

破解密码

node

nslookup

nuclei

openssl

ping

pip

python3

rm

ssh

subfinder

sudo

weechat

whois

hashcat [pcap file]

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令： `cat`

读取文件内容。用法

`cat` [文件名]

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令： cd

cd 命令用于更改当前工作目录。用法

```
cd [目录名]
```

返回上一级目录：

```
cd ..
```


终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令：cp

复制文件和目录。

用法

```
cp <source> <destination>
```


终端命令

[apt-get install](#)[bettercap](#)[cat](#)[cd](#)[cp](#)[dig](#)[dirhunter](#)[download](#)[ftp](#)[geoip](#)[git](#)[hydra](#)[john](#)[ls](#)[lynx](#)[mkdir](#)[mv](#)[mxlookup](#)[nmap](#)

命令：dig

Dig 是一个命令行工具，用于收集有关 IP 地址的信息。

```
dig <ip 地址>
```


终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令：dirhunter

Dirhunter 是一个 Web 目录发现工具。它会扫描目标网站，并显示其公开可访问的路径和页面。
适用于侦察 – 查找隐藏的管理面板、API 端点或被遗忘的页面。

安装： `apt-get install dirhunter`

用法： `dirhunter <域名>`

示例： `dirhunter example.com`

该工具将扫描目标并列出所有发现的目录和页面。

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令：download

将远程服务器上的文件下载到本地计算机。

用法

```
download <文件路径>
```


[apt-get install](#)[bettercap](#)[cat](#)[cd](#)[cp](#)[dig](#)[dirhunter](#)[download](#)[ftp](#)[geoip](#)[git](#)[hydra](#)[john](#)[ls](#)[lynx](#)[mkdir](#)[mv](#)[mxlookup](#)[nmap](#)

命令：ftp

它允许我们连接和管理远程 ftp 服务器。用法

```
ftp -h [host] -u [user] -p [password]
```


终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoiip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令: geoiip

Geoiip 是一个知名工具，可以帮助您查找给定 IP 地址的位置。

geoiip <ip 地址>

示例 geoiip 46.20.15.34

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令： git

Git 是玩家存储和分享他们编写的程序的平台。

初始化仓库 例如我们在一个有脚本的文件夹中。 `git init -n <repo name>`

提交 将提交添加到仓库。 `git commit -m <message>`

推送 将提交推送到仓库。 `git push`

拉取 拉取仓库的最新更新。 `git pull`

克隆 克隆仓库。 `git clone <repository slug> <path to clone>`

示例 `git clone example-hack-tool ./home/user/desktop/repo-folder`

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令: hydra

Hydra 是一个并行化登录破解工具，支持多种协议。

- **-u** 标志是可选的。如果省略，Hydra 会自动使用 **root** 作为默认用户名。
- **-T** 标志指定目标，格式为 **_IP:Port_**。例子: `hydra -T 192.168.1.1:22 -P ./wordlist.lst`
- **-P** 标志用于提供字典文件的路径。请确保指定正确的绝对路径或相对路径。例子: 如果您在根目录并且文件在 **downloads** 中:

`-P /downloads/wordlist.lst`

用法 (默认用户名: root): `hydra -T [ip:port] -P [wordlist]`

用法 (带用户名): `hydra -T [ip:port] -l [username] -P [wordlist]`

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令: john

john，意为“John The Ripper”，用于破解加密文本的密码。您必须先安装该软件包。

```
apt-get install john
```

john 有两种不同的用法。

- 文件密码破解

```
john /etc/passwd
```

- 解码哈希字符串

```
john <hash>
```

示例

```
john 31435008693ce6976f45dedc5532e2c1
```


终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令：ls

ls命令用于列出文件。"ls"本身会列出当前目录中的所有文件。用法 `ls`

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令: lynx

它在互联网上进行深度搜索。用法

```
lynx [search]
```


终端命令

[apt-get install](#)[bettercap](#)[cat](#)[cd](#)[cp](#)[dig](#)[dirhunter](#)[download](#)[ftp](#)[geoip](#)[git](#)[hydra](#)[john](#)[ls](#)[lynx](#)[mkdir](#)[mv](#)[mxlookup](#)[nmap](#)

mkdir

在当前工作路径中创建新目录。

```
mkdir <directory name>
```


终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令：mv

移动文件和目录，或给它们重命名。

用法

```
mv <source> <destination>
```


终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令：mxlookup

查找域的邮件服务器。

```
mxlookup <domain>
```

示例

```
mxlookup example.com
```


终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令: nmap

Nmap 是一个开源工具，用于网络扫描和漏洞检测。你可以使用 `-sV` 标志执行更详细的扫描，并了解在后台运行的服务及其版本信息。默认用法

```
nmap [ip address]
```

详细用法

```
nmap [ip address] -sV
```

指定端口

```
nmap [ip address] -port [port number]
```

示例用法以 IP 地址 **10.22.33.44** 为例。我们来列出该地址上的端口。

```
nmap 10.22.33.44
```

我们将得到的输出:

```
| PORT | STATE | SERVICE || ---- | ----- | ----- || 21 | OPEN | ftp || 22 | CLOSE | ssh || 80 | CLOSE | http |
```

STATE:

- OPEN: 该端口已定义并正在被积极使用。
- CLOSE: 这些端口已定义，但已关闭不可用。
- FORWARDED: 该端口是开放的，但它被重定向到了一个不同的端口，而不是默认端口。这意味着服务仍然可访问，但需要通过不同的端口号访问。例如，FTP 服务器通常运行在端口 21，但如果它在端口 37359 上显示为 FORWARDED，则表示对 37359 的连接会被转发到网络内部实际运行在端口 21 上的 FTP 服务。

SERVICE:

- 在后台运行于该端口上的服务。当我们进行了更详细的搜索:

```
nmap 10.22.33.44 -sV
```

我们将得到的输出:

node	PORT STATE SERVICE VERSION DESTINATION ---- ----- ----- ----- ----- 21
nslookup	OPEN ftp vsftpd 1.0.0 192.168.1.2 22 CLOSE ssh openssh 1.0.0 192.168.1.2 80 CLOSE http nginx 1.0.0 192.168.1.2
nuclei	VERSION:
openssl	此部分由 2 个部分组成。
ping	第 1 部分: 运行中的应用名称。
pip	第 2 部分: 该运行中应用的版本。如果我们知道正在运行的服务版本，并且端口是开放的，我们就可以渗透该系统。
python3	
rm	
ssh	
subfinder	
sudo	
weechat	
whois	

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令: node

此命令允许您运行游戏内脚本（带 .ts 扩展名）。默认情况下未安装。

```
node myscript.ts
```

node	
nslookup	
nuclei	
openssl	
ping	
pip	
python3	
rm	
ssh	
subfinder	
sudo	
weechat	
whois	

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令: nslookup

查找目标域的IP地址。用法

```
nslookup [domain]
```


终端命令

[apt-get install](#)[bettercap](#)[cat](#)[cd](#)[cp](#)[dig](#)[dirhunter](#)[download](#)[ftp](#)[geoiip](#)[git](#)[hydra](#)[john](#)[ls](#)[lynx](#)[mkdir](#)[mv](#)[mxlookup](#)[nmap](#)

命令: Nuclei

Nuclei 是一个快速、可定制的漏洞扫描工具。

```
nuclei -h <hosts>
```

用法要使用 Nuclei，您需要一个包含域地址的文本文件。示例: /domain_list.txt

```
example.com  
domain.com  
myanotherdomain.com
```

然后

```
nuclei -h /domain_list.txt
```


终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令：openssl

对文本进行加密或解密。加密用法

```
openssl -enc [text]
```

解密用法

```
openssl -dec [text]
```


终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令： ping

它检查是否成功向服务器发送数据包以及是否收到响应。用法

```
ping [ip address]
```

node	
nslookup	
nuclei	
openssl	
ping	
pip	
python3	
rm	
ssh	
subfinder	
sudo	
weechat	
whois	

命令: pip

Pip 是 Python 的一个包管理器。它是安装用 Python 编写的程序所必需的。安装 `apt-get install pip`

安装 Python 包 `pip install <包名>`

示例 `pip install sqlmap`

node

nslookup

nuclei

openssl

ping

pip

python3

rm

ssh

subfinder

sudo

weechat

whois

终端命令

[apt-get install](#)[bettercap](#)[cat](#)[cd](#)[cp](#)[dig](#)[dirhunter](#)[download](#)[ftp](#)[geoip](#)[git](#)[hydra](#)[john](#)[ls](#)[lynx](#)[mkdir](#)[mv](#)[mxlookup](#)[nmap](#)**命令： python3**

python3 命令允许我们运行一个 python 脚本。用法

```
python3 [/destination/to/file]
```

示例

```
python3 /downloads/net_tree.py
```

你可以在 hackdb.net 找到要运行的 python 脚本。

node	
nslookup	
nuclei	
openssl	
ping	
pip	
python3	
rm	
ssh	
subfinder	
sudo	
weechat	
whois	

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令：rm

删除文件/文件夹。用法

```
rm [文件/文件夹名称]
```


终端命令

[apt-get install](#)[bettercap](#)[cat](#)[cd](#)[cp](#)[dig](#)[dirhunter](#)[download](#)[ftp](#)[geoip](#)[git](#)[hydra](#)[john](#)[ls](#)[lynx](#)[mkdir](#)[mv](#)[mxlookup](#)[nmap](#)**命令：ssh**

- 安全外壳（SSH）是一种提供安全访问远程计算机的方法。
- 它允许您远程登录系统并执行命令，就像您坐在控制台上一样。
- 重要的是标志。
- 在ssh中，我们不使用常见的用法。
- 在-h标志下，您需要组合用户名和IP地址（不包括端口）。
- 例如：root@192.168.1.1

用法

```
ssh -h [username@ip] -p [port]
```

node	
nslookup	
nuclei	
openssl	
ping	
pip	
python3	
rm	
ssh	
subfinder	
sudo	
weechat	
whois	

终端命令

[apt-get install](#)[bettercap](#)[cat](#)[cd](#)[cp](#)[dig](#)[dirhunter](#)[download](#)[ftp](#)[geoip](#)[git](#)[hydra](#)[john](#)[ls](#)[lynx](#)[mkdir](#)[mv](#)[mxlookup](#)[nmap](#)

命令：subfinder

subfinder 是一个子域发现工具，使用被动在线来源返回网站的有效子域。它具有简单的模块化架构，并针对速度进行了优化。subfinder 只为做一件事而构建 – 被动子域枚举，并且它做得很好。

```
subfinder -d <domain>
```

示例

```
subfinder -d example.com
```

```
subfinder -d https://example.com
```

node	
nslookup	
nuclei	
openssl	
ping	
pip	
python3	
rm	
ssh	
subfinder	
sudo	
weechat	
whois	

终端命令

[apt-get install](#)[bettercap](#)[cat](#)[cd](#)[cp](#)[dig](#)[dirhunter](#)[download](#)[ftp](#)[geoip](#)[git](#)[hydra](#)[john](#)[ls](#)[lynx](#)[mkdir](#)[mv](#)[mxlookup](#)[nmap](#)**命令：** `sudo`

它允许您切换到 "root" 用户，这是计算机中最高授权的用户。如果您想，可以直接切换到 root 用户或以 root 权限运行命令。切换 root 用户

```
sudo -su
```

以 root 权限运行命令

```
sudo [command]
```

示例：

```
sudo apt-get install metasploit
```

node	
nslookup	
nuclei	
openssl	
ping	
pip	
python3	
rm	
ssh	
subfinder	
sudo	
weechat	
whois	

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令: weechat

Weechat 允许您使用仅仅您的用户名在线聊天，完全匿名。它通常用于暗网。用法 `weechat <ip address> <password>`

终端命令

apt-get install

bettercap

cat

cd

cp

dig

dirhunter

download

ftp

geoip

git

hydra

john

ls

lynx

mkdir

mv

mxlookup

nmap

命令: whois

使用 Whois 命令，您可以找到拥有域名、IP 地址或电子邮件地址的人员。用法

```
whois [域名/ IP 地址/ 电子邮件]
```


PYTHON 模块

Evil-Rm

Fern

JWT Decoder

Kimai

Net Tree

Pret

pyUserEnum

Sqlmap

WigleNet

Python 模块： Evil-Rm

连接到远程机器并执行命令。安装 `pip install evil-rm`

用法 `evil-rm -i <ip address> -u <username> -H <hash>`

重要 要使用 Evil-RM，您需要知道目标设备上某个用户的用户名和密码哈希。为此，我们建议查看 NTLM 工具。示例 `evil-rm -i 47.189.132.4 -u alex -H 09bb63bf7635f9cfd50f022e7a3b0dba`

Python 模块：Fern

一个破解路由器密码的工具，如果路由器型号是公开可用的。用法

- 从 hackdb.net 下载 fern.py。
- 安装 python `apt-get install python3`
- `python3 fern.py`
- 输入路由器型号。示例

```
python3 /home/user/downloads/fern.py 路由器型号 > WN087A2
```

PYTHON 模块

Evil-Rm

Fern

JWT Decoder

Kimai

Net Tree

Pret

pyUserEnum

Sqlmap

WigleNet

Python 模块: JWT 解码器此漏洞解码 JWT 令牌并操纵其负载以绕过安全性并提升特权。它通常用于利用弱或缺失的 JWT 签名验证机制。使用方法

- 从 hackdb.net 下载 `jwt_decoder.py`。
- 安装 python `apt-get install python3`
- `python3 jwt_decoder.py <jwt 令牌>`

示例 `python3 /home/user/downloads/jwt_decoder.py eyJ...`

Python 模块：Kimai

Kimai 易受 SameSite–Cookie–Vulnerability–session–hijacking 的攻击。攻击者可以欺骗受害者更新或升级系统，通过使用非常恶意的漏洞来窃取其易受攻击的 cookie 并控制其会话。

Kimai 在防火墙上是有效的。使用方法

- 从 hackdb.net 下载 kimai.py。
- 安装 python `apt-get install python3`
- 在 Wireshark 上开始监听。
- `python3 kimai.py <ip address>`
- Kimai 可能并不是每次都能窃取到 cookie。如果您无法获取 cookie，请再试一次。示例

```
python3 /home/user/downloads/kimai.py 46.20.15.34
```

Python 模块：网络拓扑树此漏洞利用 IP 地址作为输入生成完整的网络拓扑。通过主动和被动扫描技术，该工具识别路由器、交换机和连接的设备，以及它们的开放端口和服务。输出以树状结构可视化，以方便阅读。使用方法

- 从 hackdb.net 下载 `net_tree.py`。
- 安装 python `apt-get install python3`
- `python3 net_tree.py <ip address>`

示例 `python3 /home/user/downloads/net_tree.py 46.20.15.34`

PYTHON 模块

Evil-Rm

Fern

JWT Decoder

Kimai

Net Tree

Pret

pyUserEnum

Sqlmap

WigleNet

Python 模块: Pret

PRET 是一个用于打印机安全测试的新工具, 在鲁尔大学波鸿的硕士论文范围内开发. 它通过网络或 USB 连接到设备, 并利用给定打印机语言的功能.

用法

- 从 hackdb.net 下载 pret.py.
- 安装 python `apt-get install python3`
- `python3 pret.py <ip address>`

示例 `python3 /home/user/downloads/pret.py 46.20.15.34`

重要

- PRET 需要打印机可通过其 LAN IP 地址访问, 并且端口 9100 (RAW 打印) 已开放. 如果端口 9100 已关闭, PRET 无法与打印机通信.

Python 模块: pyUserEnum

pyUserEnum 是一个用于枚举子网用户的工具。使用方法

- 从 hackdb.net 下载 pyUserEnum.py。
- 安装 python `apt-get install python3`
- `python3 pyUserEnum.py <ip 地址>`

示例 `python3 /home/user/downloads/pyUserEnum.py 46.20.15.34`

PYTHON 模块

Evil-Rm

Fern

JWT Decoder

Kimai

Net Tree

Pret

pyUserEnum

Sqlmap

WigleNet

Python 模块: Sqlmap

Sqlmap 是一个用于测试和利用 SQL 注入漏洞的工具。安装 `pip install sqlmap`
使用 `sqlmap -u <url> <options>` 或 `python3 sqlmap.py -u <url> <options>`

可用选项列表

- 列出表: `sqlmap -u <url> -tables`
- 导出表数据: `sqlmap -u <url> -dump -table <table name>`

示例用法
 假设我们的目标是 bestecommerce.com 并且存在 SQL 漏洞。

`sqlmap -u bestecommerce.com -tables`

结果 | 表名 | | ---- | | 产品 | | 用户 |

然后 `sqlmap -u bestecommerce.com -dump -table Products`

结果 | 产品 ID | 产品名称 | 价格 | | ---- | | ---- | | ---- | | 1 | 手机 | 499\$ | 2 | 电脑 | 999\$

Python 模块: WigleNet

WigleNet 是一个在特定位置查找所有设备的工具。使用方法

- 从 hackdb.net 下载 wiglenet.py。
- 安装 python `apt-get install python3`
- `python3 wiglenet.py -lat <latitude> -long <longitude>`

示例 `python3 /home/user/downloads/wiglenet.py -lat 145.06 -long 68.592`

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

在线世界

多人模式是一个所有人共享的大世界。你看到的每一个公司站点、家庭网络和人物都是活生生的目标，而其他操作员（以及自动化的 NPC 团队）正在和你同时攻击同一批机器。

由此带来几个结果：

- **战利品会被搬空。** 一个目标被洗劫之后，它的战利品就用完了，这台机器会进入冷却（通常是几个小时），之后才会重新填满。如果一台机器看起来空空如也，那就晚点再来，或者换一个目标。
- **你不在的时候，世界照样在动。** NPC 团队会自己去刷目标，所以你一直留着的那笔肥肉，等你赶到时可能已经没了。打开网络监视器（Network Monitor），看看谁在线上活动。
- **目标不是一成不变的。** 你上周攻破的机器不会永远保持原样。它开放的服务会在两次突袭之间发生变化，所以每次都重新扫描，别指望旧的入口还管用。

本节剩下的部分会走完整个循环：找到目标、破门而入、拿走战利品，然后在不被抓到的前提下把它变成干净的钱。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

Finding Targets

You can only attack something you can reach, and you reach a box by its **IP address**. Recon is simply the work of turning a name into an IP.

Three commands do most of the job:

- `nslookup <domain>` resolves a domain to an address. For a plain machine, that address is the box itself.
- `whois <domain>` shows who owns a domain, plus contact and mail hints that help later when you phish.
- `mxlookup <domain>` resolves the **mail** server. Mail almost never hides behind a CDN, so this is a dependable way to leak a real address.

Tip: `whois <IP>` looks up the person or machine using that address, while `whois <domain>` looks up the company that owns the name. If a name surprises you, that is why.

When a target hides behind a CDN

Sometimes `nslookup` says the host is behind Cloudfire and the origin is hidden. That means the address you got is only the CDN edge, and the edge cannot be exploited. The mail record is usually not proxied, so try:

```
mxlookup targetcorp.com
```

That hands you the real **origin IP** to scan and exploit.

Reputation opens doors

Higher-value targets stay out of reach until you have built a name. Reputation climbs as you pull off jobs, and the bigger the payout, the more reputation a target expects before it will even respond. Start small and work your way up.

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

Targets & Tiers

Not every target is equally hard. Boxes come in tiers, and the tier tells you how much work getting in will take.

- **Tier 1, direct.** Reachable straight from the internet. Scan the IP, find the open service, exploit it. Great for building reputation and starter cash.
- **Tier 2, VPN gated.** You cannot touch the real box from outside. First you get a VPN certificate (by phishing an employee or by cracking a captured hash), connect with `openvpn`, and only then can you exploit the target. See *VPN-Gated Targets*.
- **Tier 3, vaults.** The prize sits deep inside a private network. You breach the edge host, then **pivot** hop by hop toward the vault at the core. See *Vaults & Pivoting*.

Higher tiers pay far more, raise heat faster, and often need reputation before the target answers at all. Climb steadily; do not expect to walk into a vault on day one.

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

Tier 1: 直连目标

Tier 1 机器直接对公网应答。这里没有门禁：只要你能解析出它的地址，就能攻击它。这也是你熟悉整套流程、攒下更高 Tier 所要求的声望的地方。

完整流程

1. 选一个目标。翻一翻目录或者网络监视器，或者顺着你挖出来的某个域名往下走。
2. 解析它。

```
nslookup targetcorp.com
```

如果结果说这台主机在 Cloudfire 后面，那个地址只是 CDN 的边缘节点，没法利用。换个思路，从邮件记录或者被动 DNS 历史里挖出真正的源站：

```
mxlookup targetcorp.com
dnshistory targetcorp.com
```

3. 摸清攻击面。

```
nmap 203.0.113.5
```

4. 把真门和陷阱分开。

```
probe 203.0.113.5
```

只对标记为 **EXPOSED** 的端口下手。**hardened** 端口是死路，还会让你增加追踪，而 **HONEYPOT** 会让你被抓。**probe** 还会告诉你攻击方式：是直接的端口漏洞利用，还是需要你自己设置 LHOST 和 LPORT 的反向 shell。

5. 利用它。打开 **msfconsole**，选出对应那个服务的模块，按 **probe** 指出的信息设置选项，然后运行。*Metasploit* 一节给出了确切的语法。

6. 拿走战利品。在机器上找到数据包并下载。这个传输是把文件搬走，而不是复制，所以它一旦落到你的机器上，别人就再也拿不到这笔收获。

7. 离开之前清理痕迹。

```
clearlogs targetcorp.com
```

入侵会把你的公网 IP 写进这台主机的访问日志。把它留在那儿，等于在给防御方的取证送材料，还会推高你的热度。

8. 变现。

```
appraise loot.dump
```

然后把它洗白或者卖掉。见 *鉴定战利品* 和 *变现*。

会遇到什么

Tier 1 给的钱最少，对你的热度也最温和，而这正是它适合刷声望的原因。可利用的服务是按目标随机决定的，机器刷新时还会重新随机一次，所以永远不要以为上周的入口现在还能用。每次都重新扫描。

ONLINE WORLD

[The Online World](#)[Finding Targets](#)[Targets & Tiers](#)[Tier 1: Direct Targets](#)[Tier 2: VPN-Gated Targets](#)[Tier 3: Vaults](#)[Breaking In](#)[VPN Certificates](#)[Keys & Decoders](#)[Vaults & Pivoting](#)[Loot Packages](#)[Appraising Loot](#)[Encrypted Loot](#)[Cashing Out](#)[The GreyMarket](#)[Heat & Hot Loot](#)[Getting Traced](#)[Proxies & Rigs](#)[Your Own Infrastructure](#)

Tier 2: VPN 限制的目标

Tier 2 公司不会把装着钱的那台机器暴露出来。从外面看，你只能看到网站，别的几乎什么都没有，而且在你进到企业内网之前，漏洞利用会被直接拒绝。想进去，就得握有那家公司专属的 **VPN 证书**。

第 1 步：拿到一份证书

有两条路，走哪条都行。

钓一个员工。 对这家公司做侦察，找出一个有名有姓的员工：`whois`、网站的关于页和联系页，还有针对邮件域名的 `mxlookup`，都能帮上忙。给他发一份带陷阱的文档，他一打开，你就在他的工作机上落下了一个 shell。他的机器上存着公司的 `.ovpn` 配置，把它下载下来。

破解一个捕获到的哈希。 如果你已经搞到了一个密码哈希，不管是从公开站点上 `sqlmap` 导出的用户数据里来的，还是从钓来的邮箱里翻到的，都可以把它锻成一份证书：

```
crack targetcorp.com
```

破解按真实时间进行，时长随 Tier 提升，而且等待是由服务器强制的，所以启动之后就去干点别的。它跑完时会生成一个证书文件。

第 2 步：把隧道拉起来

```
openvpn corp-vpn.ovpn targetcorp.com
```

隧道属于打开它的那个终端。那个终端现在忙着维持这条线，所以再开一个终端，在新的里面干活。关掉第一个，隧道就断了。

第 3 步：从内部攻这台机器

现在目标会应答了。照 Tier 1 的流程来，只是要在隧道里面做：

```
nmap 203.0.113.5
probe 203.0.113.5
```

利用那个暴露的服务，拿走数据包，在放掉隧道之前运行 `clearlogs`。

容易吃亏的地方

- 一份证书只绑定目标的**某一个实例**。这台机器一旦被洗劫并轮换，旧证书就废了，你得重新弄一份。
- 偷来的证书只开**那一家公司**的门。它不是能打开别的目标的万能钥匙。
- 在 GreyMarket 上买的**通用证书**对任何匹配的目标都有效，但连接一次就会用光。
- Tier 2 涨热度明显比 Tier 1 快。在把它变成习惯之前，先租几个代理跳板。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

Tier 3: 金库

Tier 3 是这架梯子的顶端：一个藏在企业边缘之后的私人金库，里面的加密战利品比下面所有层加起来还值钱。它没有一步是自动的。你需要声望、两把不同的钥匙、一次穿过内网的跳转，以及撤离时用的解码器。

第 0 步：找到它

金库不是公开的。它们从来不会出现在目录里，你也不可能靠扫描碰上一个。你得靠做低一层的活儿，把金库挖出来：

- **战利品会漏出线索。** 有些目标身上带着通往某个隐藏目标的指针。洗劫它们，金库就会出现在你的目录和网络视图里。
- **情报会漏出线索。** 跳转到一台 NPC 的内网主机上，把上面的情报文件下载下来。这会让你还没找到的、Tier 最低的那个隐藏目标浮出水面，所以这架梯子大致是按顺序解锁的。

第 1 步：先有声望

金库在应答你之前，会先查你的名号。如果它告诉你这个目标超出了你的水平，那条拒绝消息里的数字，就是你还得靠小活儿挣回来的差额。

第 2 步：两把钥匙，而且都要鉴定过

金库要的是两样东西，一样都不能少：

- 一份**金库 VPN 证书**，以及
- 一个**金库访问令牌**。

两者都能从突袭中掉落，也都能在 GreyMarket 黑市上交易。从突袭里出来的钥匙是加密的，而加密的钥匙会被拒收，所以在指望它之前，先把每一把都鉴定一遍：

```
appraise vault-token.key
```

第 3 步：先建隧道，再挂上辅助模块

```
openvpn vault-vpn.ovpn vaultcorp.com
```

在第二个终端里，把令牌交给目标的 metasploit 访问辅助模块：

```
authkey vault-token.key vaultcorp.com
```

在那个辅助模块挂上之前，漏洞利用会一直被拒绝。令牌是一次性的，但只有真的拿到落脚点时才会被消耗，所以就算被追踪抓住，它也不会白白浪费。

第 4 步：突破边缘，然后跳转

用常规办法拿下边缘主机，然后开始往里推进：

```
pivot vaultcorp.com
```

这会列出**前沿**：从你现在站的位置能够到达的主机。**其中只有一台是真的**。其他都是死路，碰一下就会让你增加追踪。你已经攻下的主机会泄露配置和日志内容，而读这些东西，是判断哪台候选主机能打开下一层的唯一可靠线索。

跳转到你选中的那一台：

```
pivot vaultcorp.com dbnode01
```

跳对了就会打开下一层并掉落战利品：路上是些不值钱的诱饵数据包，核心才是真正的金库。每跳完一次之后：

```
clearlogs vaultcorp.com
```

第 5 步：撤出来，再把它解开

金库战利品渗出时是**加密的**，在解码之前一文不值。你需要一个与这个金库的加密方案匹配的解码器，来自突袭掉落或者黑市：

```
decode vault.dump vault-aes.dec
```

然后像处理别的东西一样鉴定它、把它出手。

容易吃亏的地方

- 在两次跳转之间省掉 `clearlogs`，追踪会涨得很快，而一次金库行动长到足够让它攒起来。
- 随手乱戳前沿主机，是金库行动中最常见的被追踪原因。先去读漏出来的配置。
- 能的话，在行动**之前**就把解码器准备好。热度很高的时候压着一份解不开的战利品，代价很贵。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

破门而入

拿到一个可达的 IP 之后，入侵只是一套很短的流程。

1. 扫描机器。看看有什么在监听：

```
nmap 203.0.113.5
```

2. 动手之前先探测。不是每个开放端口都是真的门。probe 会替你把它们分类：

```
probe 203.0.113.5
```

- exposed（暴露）端口是真实且可利用的服务。
- decoys（诱饵）看起来是开放的，实际上什么都通不到。去戳一下只会浪费时间，还会积累一点追踪。
- honeypots（蜜罐）是陷阱。碰上一个，你的追踪就会猛涨，还可能直接让你被抓，所以别去碰它们。

3. 打真正的那个服务。打开 Metasploit，对准那个暴露的端口，运行对应的漏洞利用来拿到 shell。Metasploit 一节给出了具体命令。

可利用的服务在每个目标上都是随机的，所以让 probe 告诉你哪个端口是真的，不要假设它永远是同一个。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

VPN-Gated Targets

Tier 2 boxes do not answer the open internet. You have to be inside the company network first, and that means holding a valid **VPN certificate** for that specific target.

There are two ways to get one.

Phish an employee. Find a staff member (recon and the company site help here), send them a booby-trapped mail, and when they bite you land on their workstation. From there you can download the company **VPN config file** to your machine.

Crack a captured hash. If you pulled a password hash (from a `sqlmap` users dump or a phished inbox), turn it into a certificate:

```
crack targetcorp.com
```

Cracking takes real time based on the tier, so start it and let it run.

With a cert in hand, bring the tunnel up:

```
openvpn corp-vpn.ovpn targetcorp.com
```

A few things worth knowing about the tunnel:

- It is **typed to the terminal** that opened it. Close that terminal and the tunnel drops, so keep this one holding the line and work from another terminal.
- A cert is bound to **one instance of the target**. It keeps working for as long as that box stays put, but the moment the target is looted and rotates, the old cert stops working and you need a fresh one.
- A stolen cert only opens the company you took it from. It is not a skeleton key for other targets.

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

钥匙与解码器

除了 VPN 证书之外，还有两类工具能打开门、解开战利品。

访问钥匙能带你进入受限目标，它分两种：

- **VPN 证书**靠一条隧道把你送进去。配合 `openvpn` 使用：

```
openvpn <file> <target>
```

- **访问令牌**直接向服务验证你的身份。配合 `authkey` 使用：

```
authkey <file> <target>
```

每把钥匙上都标着它能解锁的 Tier，所以 Tier 2 的钥匙开 Tier 2 的门。

解码器用来解开加密的战利品。每个解码器只对应一种加密方案，你把它交给 `decode`（见 *加密战利品*）。

工具从哪里来

- **突袭。** 钥匙和解码器有时会作为额外战利品，在行动中一起掉落。
- **GreyMarket 黑市。** 解锁之后，你可以在那里买到正好需要的钥匙或解码器，也可以把多出来的卖掉。见 *GreyMarket*。

关于买来的证书有一点要注意：**通用证书**是从市场上买到的现成干净证书，而不是你偷来的。它对任何匹配的目标都有效，而且到手时就已经鉴定过了，但连接一次就会被用光，所以把它当成一次性的便利品，而不是永久钥匙。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

金库与内网跳转

Tier 3 目标把真正的宝贝放在一个从外面看不见的内网里。你先像攻击其他机器一样突破边缘主机，然后一层一层往里推进。这就是**内网跳转**。

列出从当前落脚点能够到达的主机：

```
pivot targetcorp.com
```

每一层都会给出一小组候选主机，也就是**前沿**，但**其中只有一台是真的可以利用的**。其余都是死路，戳一下就会让你增加追踪。已经攻下的主机会泄露配置和日志内容，读懂这些线索，才能判断哪台候选主机是真的。

跳转到你选中的主机：

```
pivot targetcorp.com dbnode01
```

选对了主机就会打开下一层并掉落战利品：路上是些不值钱的诱饵收获，核心处才是加密的金库。每跳一次之后，都要清理痕迹：

```
clearlogs
```

一直推进到核心，然后洗劫金库，撤出来。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

战利品数据包

你偷到的东西会以**不透明数据包**的形式出现：一份原始转储，名字看起来很真实，比如 `backup.sql.gz`、`users_dump.sql` 或 `wallet.keystore`。它没有查看器，你也打不开它。双击只会告诉你这是一个加密的数据包。

这是故意设计的。原始转储不会自己标明价值。一个数据包可能有两种状态：

- **未鉴定。** 你还不知道它值多少钱。去鉴定它（见 *鉴定战利品*）。
- **加密。** 它被打乱过，必须先解码（见 *加密战利品*）。

把数据包搬到你的机器上是**转移，不是复制**。你一旦把它拉走，它就从那台机器上消失了，别人再也拿不到同一份战利品。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

鉴定战利品

一份刚到手的数据包在你看清里面之前都是个谜。在终端里执行：

```
appraise <file>
```

鉴定会揭示数据包的**类型和真实价值**，并重写文件，让你能读到自己究竟偷到了什么（记录、配置、密钥之类内容的预览）。只有到了这一步，它才带上一个你能拿来决定的价格。

未鉴定的战利品无法按真实价值出售或洗白，所以先鉴定，再变现。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

加密战利品

有些数据包出来时就是**加密的**，因为防御强化的目标会把自己的核心资产打乱之后再存放。加密的数据包在你解密之前，既鉴定不出全部价值，也没法销赃。

你需要一个与该数据包加密方案匹配的**解码器**。解码器会在突袭中作为额外战利品掉落，也在 GreyMarket 黑市上流通。手里有了一个之后：

```
decode <file> <decoder>
```

解码完成后，就像对待其他数据包那样鉴定它、把它出手。

ONLINE WORLD

[The Online World](#)[Finding Targets](#)[Targets & Tiers](#)[Tier 1: Direct Targets](#)[Tier 2: VPN-Gated Targets](#)[Tier 3: Vaults](#)[Breaking In](#)[VPN Certificates](#)[Keys & Decoders](#)[Vaults & Pivoting](#)[Loot Packages](#)[Appraising Loot](#)[Encrypted Loot](#)[Cashing Out](#)[The GreyMarket](#)[Heat & Hot Loot](#)[Getting Traced](#)[Proxies & Rigs](#)[Your Own Infrastructure](#)

Cashing Out

Loot is not money until you move it. Raw packages are **hot** (traceable), so you launder or sell them instead of depositing them directly.

- **Bank and financial loot** (checks, wire logs) gets **laundered**. A cut is taken, and the cut grows while your heat is high.
- **Data loot** (database dumps, credentials, wallets) gets **sold** on the GreyMarket. List it yourself, or let an NPC broker snap up fairly-priced listings that have sat for a while.

Proceeds land in your bank balance. Always appraise before you list, because an un-appraised package fences for nothing.

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

The GreyMarket

`greymarket.net` is where operators trade. It has two rooms.

The flea market

The open floor is player to player. Hit **Sell an item**, pick a loot file from your own machine, and set a price. The dialog shows recent low, average, and high prices for that kind of item so you can price it sanely. Other operators buy your listings, and you can buy theirs. Selling hands the file to the buyer and removes it from your machine. If nobody bites, an NPC broker may eventually clear a fairly-priced listing so the floor keeps moving.

The black market

A locked back room for **access keys and decoders**. Getting in costs a one-time **100,000** fee from your clean bank funds. Once it is unlocked you can:

- **Buy tools** from a catalog: the exact key or decoder you need for a target, priced by tier.
- **Sell tools** you looted or no longer need.

Bought tools arrive already identified and land in your downloads, ready to use.

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

热度与烫手战利品

每一次行动都会推高你的**热度**。热度就是这个世界还记得你闹了多大动静。

- 刚偷来的战利品是**烫手的**。在热度很高的时候处理它，代价更大：洗钱分成更高，销赃价更差。
- 热度会随时间自行冷却。如果一笔活儿变现起来感觉太贵，就低调一阵，让它降下来。
- 更大的收获和防御更强的目标会更快推高热度，但回报也高得多。这就是你在做的取舍。

热度堆得太高，线上就会变得危险：盯着一台机器的其他操作员可能会在你撤退的路上抓住你。在贪心和暴露之间找好平衡。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

被追踪

每一个动静大的操作，都会让你正在进行的这笔活儿上的追踪进度条往上涨：戳诱饵、踩到蜜罐，或者在一台机器上待得太久。让进度条填满，你就被追踪了。

一旦发生，这次行动当场作废：连接断开，那个目标会把你挡在门外一段时间，你的热度还会上升。

怎么保持干净：

- 相信 probe，不要去打诱饵或蜜罐。
- 每处理完一台主机就运行 clearlogs，在内网跳转时尤其要这么做。
- 租代理跳板来吸收热度和追踪（见 代理与装备）。
- 如果一笔活儿越来越危险，就退出来让局势冷下去，别去赌运气。

ONLINE WORLD	
The Online World	
Finding Targets	
Targets & Tiers	
Tier 1: Direct Targets	
Tier 2: VPN-Gated Targets	
Tier 3: Vaults	
Breaking In	
VPN Certificates	
Keys & Decoders	
Vaults & Pivoting	
Loot Packages	
Appraising Loot	
Encrypted Loot	
Cashing Out	
The GreyMarket	
Heat & Hot Loot	
Getting Traced	
Proxies & Rigs	代理与装备
Your Own Infrastructure	

代理与装备

有两项升级会不声不响地让每一笔活儿都更安全、更快。两者都在 `greymarket.net` 的 Black Market 后屋 **Upgrades** 标签页出售，用你在市场上赚到的 ₿ 支付。

代理跳板。 每租一个跳板，你的流量就多经过一个中继，从而降低你每笔活儿积累的热度。跳板越多，脚印越安静；如果你打算经常打大目标，这就是你最主要的防线。

装备等级。 升级装备能让入侵和下载跑得更快。等级越高，突袭里那些慢环节就越短，比如破解和数据渗出，而在战利品被人抢的时候，每一秒都很关键。

把早期的利润花在这上面。一个更冷静、更快的操作员，被对手抢走的战利品更少，被抓的次数也少得多。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

你自己的基础设施

你破进去的那些东西，你也可以自己来经营。租一台机器、租一个域名、从上面对外提供站点，你就跟这个世界里任何一家公司一样成了目标。这一页是手册的防守面。

租机器和租名字

主机商在自己的控制台里卖服务器，注册商按天或按月出租域名。两者都是按固定周期预付：过期的租约会停止服务，过期的域名最终会重新回到市场，所以在那之前就去控制台续期。付款可以用 LCB 账户里的干净余额，也可以用卡，而偷来的卡跟你自己的卡一样好使。

你在哪里买名字很要紧，因为 **whois** 会把它说出来：

- **Namecheap** 最便宜，并且会公开你的注册人信息，任何查这个域名的人都能看到背后的联系方式。
- **GoDiddy** 每天贵一些，但它卖出的每个域名都自带 WHOIS 隐私，同样的查询回来时是被遮住的。

隐私藏的是你是谁。它对你的机器在哪里毫无作用，而那正是下一节的内容。

把名字指向机器

注册商和 Cloudfire 都会给你一个 DNS 管理界面来管你名下的名字：A、CNAME、MX 和 TXT 记录。把根（@）的 A 记录指向你服务器的地址，站点就能在那个域名上打开。删掉这条记录，站点就灭了。

把源站藏住

把一个名字放到 Cloudfire 后面，公开的答案就被换成了 CDN 的边缘地址。**nslookup** 交出边缘，**whois** 根本不报地址，而边缘本身没法利用。这层保护是真的，但它永远不会强过你这个区的历史。三条规则：

1. 从第一次保存起就带着代理保存。 Cloudfire 的添加站点表单会替你这么做。而在注册商的 DNS 面板里，Proxied 那个勾一开始是没勾上的，用那种状态把你的地址存下来，哪怕只有一次，哪怕只有一分钟，就是丢掉源站最常见的方式。世界会记下一个名字在没有代理时被看到的每一个地址，而 **dnshistory mysite.com** 会把这份记录永远读回来。事后再打开代理，只会藏住今天的答案，不会撤回任何已经公开的东西。一个从第一条记录起就走代理的区完全没有历史，那才是你要的状态。要是地址已经泄了，唯一真正的补救是换到一台新地址的机器上，并且从此不再把它明着发出去。

2. 区里的每一个名字都算。 一条没走代理的 `dev` 或 `staging` 记录交出去的是跟根一样的机器，而 `subfinder` 会把你区里的每个名字都列出来，所以你忘掉的那条一定会被找到。

3. 不要发布指向你自己机器的 MX 记录。 邮件记录没法走代理，而 `mxlookup` 会直接从你的区里读出邮件主机的地址。公司的源站就是这么被拿走的，你的也一样。

加固后面那台机器

Cloudfire 的 Security 页按服务器出售防御层，每一层用干净的钱一次性买下：

| 层 | 作用 || ---- | ---- || Intrusion Detection (IDS) | 记录每一次尝试并提醒你。它自己不拦。 || Network Firewall | 把一个服务端口从开放互联网上过滤掉，封住一条进来的路。 || Web Application Firewall | 检查网页流量，拦住冲着 Web 层来的漏洞利用。 || Honeypot Trap | 摆一个诱饵服务。攻击它的人当场被追踪。 || Managed Auto-Patch | 让每个服务都打上补丁，不留可利用的弱点。 || Smart Firewall (IPS) | 一步走错，攻击者的地址就被这台机器永久封禁。 |

同一个面板会列出最近的入侵尝试，连着每一次是从哪个地址来的。那是有人已经找到你的提前预警。

这些层故意做得很贵，所以要按机器来买：对外提供站点的机器要把 Web 层盖住，存着值钱东西的机器要 Auto-Patch。而且顺序别搞反。先把地址藏起来。源站还躺在被动 DNS 里的加固机器不是安全，只是倒得慢一点的目标。

ONLINE WORLD

The Online World

Finding Targets

Targets & Tiers

Tier 1: Direct Targets

Tier 2: VPN-Gated Targets

Tier 3: Vaults

Breaking In

VPN Certificates

Keys & Decoders

Vaults & Pivoting

Loot Packages

Appraising Loot

Encrypted Loot

Cashing Out

The GreyMarket

Heat & Hot Loot

Getting Traced

Proxies & Rigs

Your Own Infrastructure

从租来的服务器上干活

每一个吵闹的动作都会在线路上留下一个地址。它会进到目标的访问日志、任何盯着那台主机的人的监控里，以及那台机器发出的每一条按地址的封禁。默认情况下，这个地址就是你自己机器的地址。

租来的机器会改变这一点。在你租的服务器上开一个 shell，只要这个 shell 还开着，你启动的一切都从它那儿出去：

```
ssh -h operator@203.0.113.5
```

从那一刻起，目标看到的是租来那台机器的地址，而不是你的。关掉最后一个 shell，你就回到自己的连接上。你自己的机器在 `ifconfig` 里仍然报的是它真实的地址：只有你从服务器上启动的活儿才走服务器出去。

这份租金值在哪

- **封禁打的是机器，不是你。** Smart Firewall 会永久封掉走错那一步的地址。要是那是台租来的机器，你就烧掉这份租约再租一台。要是那是你自己的线路，这个目标就对你彻底关门了。
- **监控点出的是那台机器。** 盯着一台主机的人能看到每次尝试的来源地址，所以通过租来的机器干活，你自己的地址就不会进他们的记录。
- **忘记擦掉的一行指向的是别处。** `clearlogs` 仍然是该有的习惯，但你漏掉的那条指的是租来的机器。

实际细节

- 想开多少 shell 都行。只要最后一个还没关，你就一直从那台机器出去。
- 这条路由跟着你的会话：掉线就结束，shell 回来它也跟着回来。
- 过期的租约什么都不转发。在靠它办事之前先续期。
- 连上别人的 Wi-Fi 也能同样地挪动你的地址。手上没有机器时，这是应对封禁的便宜办法。

把对外提供站点的机器和你干活用的机器分开。站点机器有一个域名直直地指着它，这让它成为你最容易被找到的地址，而那正是你最不愿意出现在受害者日志里的地址。

Working From a Rented Server

Operator Commands

ONLINE WORLD	
The Online World	
Finding Targets	
Targets & Tiers	
Tier 1: Direct Targets	
Tier 2: VPN-Gated Targets	
Tier 3: Vaults	
Breaking In	
VPN Certificates	
Keys & Decoders	
Vaults & Pivoting	
Loot Packages	
Appraising Loot	
Encrypted Loot	
Cashing Out	
The GreyMarket	
Heat & Hot Loot	
Getting Traced	
Proxies & Rigs	
Your Own Infrastructure	

操作员命令

这些命令只存在于在线世界。在单人模式里运行，只会提示你它仅限多人模式。

侦察与监视

| 命令 | 作用 || ---- | ---- || `probe <ip>` | 深度漏洞扫描。把每个端口分类为暴露、加固或蜜罐。比 `nmap` 更慢，也更吵。 || `dnshistory <domain>` | 被动 DNS。列出这个域名曾经出现在哪些地址上，这也是你绕到 CDN 背后的办法。 || `watch <target>` | 开始监视一个目标。 || `watch off <target>` | 停止监视它。 || `watch who <target>` | 扫一遍这个目标，看看还有哪些操作员在监视它。 |

`watch` 会把一个目标接到你的线上：这台主机上的入侵尝试和战利品渗出都会流进 **网络监视器**（Network Monitor）应用，你可以在那里开始抓包把它们记下来。任何东西都不会全局广播，所以只有真的去监视了的操作员才看得到这些流量。在动手之前先对一台机器运行 `watch who`，看看有没有人正反过来盯着你。

访问

| 命令 | 作用 || ---- | ---- || `crack <target>` | 把捕获到的密码哈希变成一份 VPN 证书。按真实时间运行。 || `openvpn <cert> <target>` | 把隧道拉起来。由打开它的那个终端持有。 || `authkey <token> <target>` | 在运行漏洞利用之前，用访问令牌挂上金库的访问辅助模块。 |

内网里面

| 命令 | 作用 || ---- | ---- || `pivot <target>` | 列出从落脚点能够到达的前沿主机。 || `pivot <target> <host>` | 跳转到一台主机，打开下一层。 || `clearlogs <target>` | 把你的 IP 从那台主机的访问日志里抹掉。每跳一次之后都要运行。 |

战利品与钱

| 命令 | 作用 || ---- | ---- || `appraise <file>` | 鉴定一个数据包：揭示战利品的真实价值，也让钥匙或解码器变得可用。 || `decode <loot> <decoder>` | 用匹配的解码器解密加密战利品。一次性使用。 || `launder <check>` | 把偷来的支票通过 Mixer 洗成干净资金。抽成会随你的热度上升。 || `market` | 列出黑市的商品目录。 || `market buy <id>` | 用银行里的干净资金买下一件商品。 || `market sell <file>` | 卖掉你手上的钥匙或解码器。 |

Working From a Rented Server	只有银行支票才走 Mixer。数据类战利品（转储、凭证、钱包）则是在 greymarket.net 上出售。不管走哪条路，都要先鉴定：没鉴定过的数据包销赃时一文不值。
Operator Commands	留下你的印记 命令 作用 ---- ---- <code>deface <message></code> 覆写你已经拿到 shell 的那台主机的首页。 <code>deface</code> 只有在你已经拿到 shell、而且那个目标确实对外提供网站时才有用。这次写入是持久且全局的：每一个访问那个首页的玩家都会看到你的留言，直到主机自己重置。它一分钱都不给，所以纯粹是在操作员之间赚名声。